Container & Image Build Standards

Engineering Handbook · Internal · Owner: Platform Engineering

Purpose

Every service we run — api-service, auth-service, worker-service, ingestion-service, gateway, scheduler — ships as a container image pushed to Artifact Registry and deployed to Cloud Run or GKE. Two classes of build/deploy failure recur: the runtime cannot pull the image because of missing IAM (BUG-1047), and admission control rejects the pod because the image runs as root (BUG-1049). This page is the prescriptive how-to for building images that pass security policy and pull cleanly in every environment.

Standards

Build a minimal, non-root image

Start from a slim, hardened base, install dependencies in a builder stage, and run as a dedicated non-root user. Admission control blocks any pod whose container would run as UID 0 (BUG-1049), so a non-root `USER` in the Dockerfile is mandatory, not optional. Bind the app to `0.0.0.0:$PORT` and expose a health endpoint for probes.

```
FROM python:3.12-slim AS build
WORKDIR /app
COPY requirements.txt .
RUN pip install --no-cache-dir --prefix=/install -r requirements.txt

FROM python:3.12-slim
# create an unprivileged user and run as it
RUN useradd --uid 10001 --no-create-home --shell /usr/sbin/nologin appuser
COPY --from=build /install /usr/local
COPY --chown=appuser:appuser . /app
WORKDIR /app
USER 10001
EXPOSE 8080
CMD ["uvicorn", "main:app", "--host", "0.0.0.0", "--port", "8080"]
```

Reinforce it at the platform layer so a mistake in the Dockerfile is still caught:

```
# Kubernetes pod securityContext
securityContext:
 runAsNonRoot: true
 runAsUser: 10001
 allowPrivilegeEscalation: false
 readOnlyRootFilesystem: true
```

Grant the runtime service account pull access

A deploy fails to start with `denied: Permission artifactregistry.repositories.downloadArtifacts` when the service account cannot read the repository (BUG-1047). Grant `roles/artifactregistry.reader` on the specific repository (least privilege — scope it to the repo, not the whole project) to the runtime service account.

```
gcloud artifacts repositories add-iam-policy-binding platform-images \
 --location=us-central1 \
 --member="serviceAccount:api-service@PROJECT.iam.gserviceaccount.com" \
 --role="roles/artifactregistry.reader"
```

Use fully-qualified, region-correct image references

Image-pull failures are often a wrong path or region, not just IAM. Reference images by their full Artifact Registry path *and* an immutable digest so the pulled bytes are exactly what was tested, and make sure the region in the path matches the repository.

```
# Fully-qualified, pinned by digest (not a mutable :latest tag)
us-central1-docker.pkg.dev/PROJECT/platform-images/api-service@sha256:abcd1234...

# Verify the SA can pull before you roll out
gcloud artifacts docker images list \
 us-central1-docker.pkg.dev/PROJECT/platform-images --include-tags
```

Common failures and fixes

- `denied: Permission artifactregistry.repositories.downloadArtifacts` at startup → grant the runtime service account `roles/artifactregistry.reader` on the repository and confirm the image path/region (BUG-1047).
- Pod rejected by admission control for running as root → add a non-root `USER` in the Dockerfile and set `runAsNonRoot`/`runAsUser` in the pod spec (BUG-1049).
- Image pulls in one region but not another → the region in the image path does not match the repository; use the fully-qualified path.
- Deployed bytes differ from what was tested → pin images by `@sha256` digest instead of a mutable tag.

Checklist

- Dockerfile declares a non-root `USER` (UID > 0) and builds from a slim/hardened base.
- Pod spec sets `runAsNonRoot: true`, a non-zero `runAsUser`, and disables privilege escalation.
- App binds `0.0.0.0:$PORT` and serves a health endpoint for probes.
- Runtime service account has `roles/artifactregistry.reader` scoped to the repository.
- Image referenced by fully-qualified, region-correct path and pinned by digest.
- Pull verified (`gcloud artifacts docker images list`) before rollout.

Related incidents

BUG-1047, BUG-1049